HỌC PHẦN 20261A - BLOCKCHAIN

BÀI TẬP VỀ NHÀ SỐ 1

Bài 3 - Bitcoin Script và mật khẩu

Nhóm	Họ và tên	Mã học viên
12 - R2R	Trần Mạnh Đạt	20252607M
	Trần Hoàng Sơn	20252606M
	Nguyễn Đức Hoàng	20252603M

Ngày 14 tháng 10 năm 2026

Tài liệu gốc: Stanford CS251 - Assignment #1 (Fall 2023)

Bài 3. Bitcoin Script và mật khẩu

Đề bài. ***Problem 3. Bitcoin script.*** *Alice is on a backpacking trip and is worried about her devices containing private keys getting stolen. She wants to store her bitcoins in such a way that they can be redeemed via knowledge of a password P. Accordingly, she stores them in the following ScriptPubKey address:*

```
OP_SHA256
<0xeb271cbcc2340d0b0e6212903e29f22e578ff69b>
OP_EQUAL
```

a. *Write a ScriptSig script that will successfully redeem this UTXO given the password P. Hint: it should only be one line long.*

b. *Suppose Alice chooses a six character password P. Explain why her bitcoins can be stolen soon after her UTXO is posted to the blockchain. You may assume that computing SHA256 of all six character passwords can be done in reasonable time.*

c. *Suppose Alice chooses a strong 30 character passphrase P. Is the ScriptPubKey above a secure way to protect her bitcoins? Why or why not? Hint: reason through what happens when she tries to redeem her bitcoins.*

Bài làm

Lỗi độ dài trong đề Fall 2023

`OP_SHA256` luôn trả về digest 32 byte. Hằng `eb271cbcc2340d0b0e6212903e29f22e578ff69b` có 40 ký tự hex, tức 20 byte. Hai byte-string khác độ dài không thể bằng nhau, nên script đúng nguyên văn là **không thể tiêu**, ngay cả khi biết mật khẩu P.
Ý đồ của bài là một hashlock. Có thể sửa bằng cách đổi opcode thành `OP_SHA1` để phù hợp với digest 20 byte, hoặc giữ `OP_SHA256` và thay hằng bằng digest SHA256 32 byte của P. Các câu trả lời sau dùng phiên bản đã sửa.

a) ScriptSig và vị trí trong giao dịch

ScriptSig cần dùng chỉ có một dòng:

```
<P>
```

Đây chỉ là dữ liệu mở khóa nằm trong input của *giao dịch chi tiêu*, không phải toàn bộ transaction. ScriptPubKey chứa hashlock đã được ghi trong output của *giao dịch cấp tiền* trước đó. Hai giao dịch có cấu trúc:

```
Funding transaction (giao dich truoc)
  Output:
    value:          <so bitcoin>
    ScriptPubKey:   OP_SHA256 <h> OP_EQUAL
Spending transaction (giao dich moi)
  Input:
    outpoint:       <funding_txid>:<output_index>
    ScriptSig:      <P>
  Output:
    value:          <so bitcoin muon chuyen>
    ScriptPubKey:   <dieu kien khoa cua nguoi nhan>
```

Với $h = \text{SHA256}(P)$ trong phiên bản đã sửa, node ghép ScriptSig với ScriptPubKey của UTXO cũ và thực thi:

$$\langle P \rangle \xrightarrow{\texttt{OP_SHA256}} \text{SHA256}(P) \xrightarrow{\text{so sánh với } h} \texttt{TRUE}.$$

Như vậy, câu trả lời một dòng cho phần a vẫn là `<P>`; phần còn lại giải thích `<P>` nằm ở đâu và cách node dùng nó để xác thực giao dịch.

b) Mật khẩu sáu ký tự

Digest đã công khai trong output. Kẻ tấn công có thể duyệt ngoại tuyến toàn bộ không gian mật khẩu sáu ký tự, băm từng ứng viên và so sánh với digest. Khi tìm được P, họ tự tạo giao dịch tiêu UTXO về địa chỉ của mình. SHA256 được thiết kế để tính nhanh nên không thay thế một hàm password hashing có salt và có chi phí tính toán cao.

c) Passphrase mạnh 30 ký tự

Passphrase mạnh ngăn được vét cạn trước khi Alice tiêu coin, nhưng hashlock đơn lẻ vẫn không an toàn:

1. Alice phát giao dịch; P xuất hiện công khai trong ScriptSig.
2. Nút mạng hoặc miner đọc P từ mempool.
3. Họ tạo giao dịch cạnh tranh dùng cùng P, chuyển coin về địa chỉ của họ và có thể đặt phí cao hơn.
4. Script không có chữ ký ràng buộc người nhận hoặc nội dung giao dịch, nên giao dịch thay thế cũng hợp lệ.

Do đó, cần kết hợp hashlock với điều kiện chữ ký như `OP_CHECKSIG`.